



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Ubiquiti UniFi OS KEV Cluster: Command Injection, Path Traversal, and Access-Control Risk

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-25
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Ubiquiti UniFi OS KEV Cluster: Command Injection, Path Traversal, and Access-Control Risk - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-25 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Ubiquiti UniFi OS KEV Cluster: Command Injection, Path Traversal, and Access-Control Risk

1. Executive Summary

CISA added three Ubiquiti UniFi OS vulnerabilities to the Known Exploited Vulnerabilities catalog on 2026-06-23 with a 2026-06-26 federal mitigation due date. The cluster is operationally urgent because UniFi OS commonly administers network infrastructure, and successful exploitation can enable unauthorized system changes, file access paths that may lead to account access, or command injection from a malicious actor with network access.

Defender priority is immediate inventory and mitigation of exposed management surfaces, because CISA KEV inclusion indicates active exploitation evidence and the remediation window for federal civilian agencies is 2026-06-26. This report uses a 72-hour source window for the CISA KEV update and supporting public reporting.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-34908, CVE-2026-34909, CVE-2026-34910
Product / Component	Ubiquiti UniFi OS
Weakness	CWE-284, CWE-22, CWE-20; improper access control, path traversal, and improper input validation with command-injection impact
Severity	Critical operational priority due to KEV status and management-plane impact
Affected Versions	See vendor advisory and NVD records; validate installed firmware/software against vendor fixed release guidance
Fixed Versions	See vendor advisory linked in References
Disclosure / KEV Date	CISA KEV date added: 2026-06-23
Exploitation Status	Known exploited per CISA KEV; ransomware use not reported by CISA for this entry
Required Action Due Date	2026-06-26 per CISA KEV/BOD 26-04 guidance

3. Source Review & Confidence

Source	Contribution	Confidence
CISA KEV catalog	Authoritative exploitation status, due date, and required action	High
Ubiquiti Security Advisory Bulletin 064-064	Vendor remediation reference cited by CISA	High
NVD CVE-2026-34908	CVE record reference	High
NVD CVE-2026-34909	CVE record reference	High
NVD CVE-2026-34910	CVE record reference	High

BleepingComputer	Supporting public defender context on active exploitation warning	High
------------------	---	------

Confidence is high for exploitation status, affected product naming, required action, due date, and CWE mapping because those fields are taken from CISA KEV and vendor/NVD references. Public reporting is used only as supporting context; this report does not assert victim counts or actor attribution because those details were not corroborated in the retrieved sources.

4. Vulnerability Details

- CVE-2026-34908 allows unauthorized system changes through improper access control according to CISA KEV.
- CVE-2026-34909 is a path traversal issue that can expose files on the underlying system and may be manipulated toward account access.
- CVE-2026-34910 is improper input validation that can permit command injection by an actor with network access.

The core defensive issue is not merely patch availability; it is whether the affected management plane is reachable from untrusted networks or from partner/MSP networks that could be abused as staging points. Treat management-plane exposure, credential reuse, and insufficient segmentation as co-factors that can turn device exploitation into broader intrusion risk.

5. Attack Scenarios

- An attacker with network reachability to the affected management interface exploits the flaw and modifies device state or executes commands, then establishes persistence or a secondary access path.
- A threat actor targets MSP-managed or branch deployments to pivot from network-management infrastructure into downstream customer or site networks.
- In OT, facility, airport, or remote telemetry environments, compromise of bridge/controller infrastructure creates disruption and lateral-movement risk even when the device itself is not business-data bearing.

6. Threat Landscape & Exploitation Status

CISA KEV inclusion means exploitation has been observed or credibly evidenced. No specific malware family, ransomware crew, or named intrusion set is attributed in the authoritative CISA fields retrieved for this report, so hunting should focus on anomalous management-plane access, unexpected configuration change, command execution, and post-exploitation behavior rather than actor-specific IOCs.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing or partner-facing management service	Highest priority because exploitation can be attempted without first compromising an internal workstation.
Internal network-management segment	Still high risk because compromised VPN, MSP, admin workstation, or helpdesk account can reach the device.
Aviation/aerospace facility networks	Relevant where network controllers, serial gateways, facility systems, or airport support systems are managed across segmented but interconnected networks.
Patched and isolated deployment	Reduced risk, but verify logs for exploitation attempts before assuming clean state.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Network / Infrastructure	Inventory affected products and firmware/software versions; apply vendor

		mitigation or fixed release immediately.
Critical	Security Operations	Identify exposed management interfaces; restrict access to dedicated admin networks and trusted jump hosts.
High	Detection Engineering	Enable and retain management-plane logs, authentication logs, config-change logs, EDR/NDR telemetry, and firewall flow records.
High	Incident Response	Review device logs around 2026-06-23 and earlier for suspicious login, parameter anomalies, configuration changes, new accounts, unexpected outbound traffic, or reboot patterns.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Management interface accessed from non-admin network	Firewall, VPN, proxy, NDR	Surface unauthorized reachability and scanning.
Configuration export/import, account change, or device reboot outside maintenance	Device/syslog/SIEM	Identify post-exploitation or operator activity.
Suspicious command or shell metacharacters in web parameters	WAF, reverse proxy, web logs	Detect command-injection probing where logs capture request parameters.

9.2. Sigma / Detection Rule

```

title: Network Device Management Plane Access From Non Admin Source
status: experimental
description: Detects access to vulnerable network-device management interfaces from sources outside approved admin ranges. Tune destination lists to affected Ubiquiti UniFi OS assets.
logsource:
  category: firewall
  product: generic
detection:
  selection:
    destination_port:
      - 80
      - 443
      - 8443
      - 8080
    filter_admin_source:
      source_ip|cidr:
        - 10.10.10.0/24
        - 10.20.20.0/24
  condition: selection and not filter_admin_source
fields:
  - source_ip
  - destination_ip
  - destination_port
  - url
falsepositives:
  - Newly commissioned admin jump hosts not yet in the allow list

```

level: high

9.3. Hunt Query

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemotePort in (80, 443, 8080, 8443, 22)
| where RemoteUrl has_any ("unifi", "ui.com", "lantronix", "eds5000") or RemoteIPType == "Public"
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName,
InitiatingProcessAccountName, RemoteIP, RemotePort, RemoteUrl
| order by Connections desc
```

10. Threat Hunting

10.1. Hunt Hypothesis

If exploitation or pre-exploitation reconnaissance occurred, defenders may see unusual management-plane access from non-admin sources, abnormal device configuration activity, suspicious command syntax in web requests, or post-exploitation outbound connections from infrastructure that normally has limited egress.

10.2. Hunt Query

```
DeviceEvents
| where Timestamp > ago(14d)
| where ActionType has_any ("Configuration", "UserAccount", "ServiceInstalled",
"FirewallSettingChanged")
| where DeviceName has_any ("unifi", "ubnt", "lantronix", "eds5000", "network-controller")
| project Timestamp, DeviceName, ActionType, InitiatingProcessAccountName, AdditionalFields
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Applies where the vulnerable management service is reachable from untrusted networks.
T1059	Command and Scripting Interpreter	Relevant to command-injection impact where attacker-controlled commands execute on the device.
T1087	Account Discovery	Plausible post-exploitation follow-on for exposed management devices; hunt only, not source-confirmed.
T1562	Impair Defenses	Plausible if attackers alter network-device configuration; hunt only, not source-confirmed.

12. Validation / Lab Testing

No exploit reproduction was performed during this automated daily run. Validation completed: CISA KEV feed retrieval, source URL collection, report render QA, and PDF text extraction. Recommended local validation is defensive: version inventory, reachability tests from untrusted segments, log-retention checks, and SIEM query dry-runs against management-plane telemetry.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Asset Management	Produce an affected-product inventory and

		owner list today.
Critical	Infrastructure	Patch or mitigate per vendor guidance before the CISA due date where applicable.
High	SOC	Run the included hunts and review results for suspicious management-plane access.
Medium	GRC / Third Party Risk	Ask MSPs and aviation/aerospace facility partners whether affected devices are present in managed environments.

14. References

- [1] CISA KEV catalog. https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [2] Ubiquiti Security Advisory Bulletin 064-064. <https://community.ui.com/releases/Security-Advisory-Bulletin-064-064/84811c09-4cf4-42ab-bd61-cc994445963b>
- [3] NVD CVE-2026-34908. <https://nvd.nist.gov/vuln/detail/CVE-2026-34908>
- [4] NVD CVE-2026-34909. <https://nvd.nist.gov/vuln/detail/CVE-2026-34909>
- [5] NVD CVE-2026-34910. <https://nvd.nist.gov/vuln/detail/CVE-2026-34910>
- [6] BleepingComputer. <https://www.bleepingcomputer.com/news/security/cisa-warns-of-max-severity-ubiquiti-flaws-exploited-in-attacks/>